

Governance, Approvals & Escalation (Third-Party Security Program)

Document classification: Internal

Document owner: Third-Party Security Program Owner

Version: 0.1

Effective date: _____

Review cadence: Every 12 months or upon material change

1. Purpose

This document defines decision forums, approval authority, and escalation paths for third-party security assessments, onboarding decisions, and exceptions to minimum security requirements.

2. Decision forums

2.1 Third-Party Security Review (TPSR)

Purpose: operational governance for supplier tiering decisions, due diligence outcomes, control gaps, and onboarding readiness.

Standing attendees (minimum):

- Third-Party Security Program Owner (or delegate) (chair)
- Security Engineering/Architecture representative
- Procurement representative
- Legal/Privacy representative (as required)
- Business Service Owner (supplier sponsor)
- IT/Platform Owner (where integration/connectivity is required)

Cadence:

- Weekly (or ad hoc for urgent onboarding)

Inputs:

- Completed Tiering Intake Template
- Evidence pack responses and gap log
- Proposed integration pattern and required controls
- Exception requests (if any)

Outputs:

- Tier confirmed (Critical / Important / Low)
- Onboarding decision (approve / approve with conditions / reject)
- Actions, owners, and due dates recorded

2.2 Senior Risk Acceptance Forum (SRAF)

Purpose: residual risk acceptance for Critical suppliers with material gaps, high privilege, elevated connectivity, significant data exposure, or outsourcer/MSP characteristics.

Attendees (minimum):

- Senior Technology/Security leader (chair)
- Third-Party Security Program Owner
- Business Service Owner
- Technology Risk representative (where applicable)
- Legal/Privacy representative (as required)

Cadence:

- Monthly and ad hoc for escalations

Outputs:

- Residual risk acceptance decisions for material items
- Approval of time-bound remediation plans for high-risk gaps

3. Approval authority (by tier)

3.1 Low (Tier 3)

Approval to proceed:

- Security reviewer + Business Service Owner

Contract security clauses:

- Procurement + Legal/Privacy (as required)

3.2 Important (Tier 2)

Approval to proceed:

- Security reviewer + Business Service Owner
- Procurement confirmation of process completion

Escalation triggers (TPSR required):

- Any privileged access requested
- Any integration beyond SSO (e.g., API, agent, connectivity)
- Any meaningful PII processing at scale

3.3 Critical (Tier 1)

Approval to proceed requires:

- Security Engineering/Architecture approval of the integration pattern and baseline controls
- Business Service Owner endorsement
- Procurement + Legal/Privacy completion of contractual security requirements
- SRAF endorsement where any of the following apply:
 - outsourcer/MSP with operational responsibility
 - persistent network connectivity (VPN/private link) or inbound connectivity
 - production privileged access

- supports a critical business service or regulatory reporting

4. Outcomes and decision types

TPSR decisions must be recorded as one of:

- **Approved:** baseline met; onboarding may proceed.
- **Approved with Conditions:** onboarding may proceed only once conditions are met (or by a specified date), e.g. logging enabled, SSO enforced, access restricted, contractual clause agreed.
- **Rejected / Deferred:** onboarding cannot proceed due to unacceptable risk or incomplete information.

5. Escalation path (security gaps and urgent onboarding)

5.1 Standard escalation

1. Security reviewer identifies control gaps and required remediation.
2. Supplier provides remediation plan and timelines; Security confirms feasibility.
3. If remediation is not achievable pre-onboarding, an **Exception Request** is raised with compensating controls and expiry.
4. Approval authority is applied per Section 6.

5.2 Urgent onboarding / business critical timelines

Where business timelines require onboarding before full remediation:

- Security must implement compensating controls (technical preferred), such as:
 - reduced privilege / scoped roles
 - brokered access (PAM/JIT), session logging
 - segmentation / restricted connectivity
 - enhanced monitoring and alerting
- Residual risk acceptance must be documented and approved per tier.

- A fixed remediation date and re-validation checkpoint must be set.

5.3 Supplier incident or breach notification

If a supplier notifies a security incident or breach:

- Security initiates incident triage and convenes TPSR on an emergency basis.
- For Critical suppliers, SRAF must be notified and briefed on impact, containment, and next steps.
- Re-tiering and reassessment are triggered if scope changes or new risks emerge.

6. Exception approval authority

Exceptions are time-bound deviations from minimum requirements and must include: gap, compensating controls, owner, expiry, remediation plan.

6.1 Low (Tier 3) exceptions

Approver:

- Third-Party Security Program Owner (or delegate)

6.2 Important (Tier 2) exceptions

Approvers:

- Third-Party Security Program Owner (or delegate) + Business Service Owner

Escalate to SRAF if:

- Exception involves privileged access, persistent connectivity, or meaningful PII at scale.

6.3 Critical (Tier 1) exceptions

Approvers (minimum):

- Senior Technology/Security leader (residual risk acceptance authority)

- Third-Party Security Program Owner
- Business Service Owner

SRAF endorsement required for any material exception, including:

- lack of MFA/SSO for admin access
- insufficient logging/auditability
- inability to meet incident notification commitments
- unresolved critical vulnerabilities without credible plan
- unclear sub-processor visibility for material service components

Rules:

- Exceptions must have an **expiry date** and cannot be “open-ended”.
- Exceptions must define **compensating controls** and a **re-validation checkpoint**.
- Re-approval is required upon renewal, scope change, or trigger event.

7. Records and evidence

The following must be retained for auditability:

- Tiering intake record and tier rationale
- Evidence pack responses and gap log
- Onboarding decision record (approved/conditional/rejected) with conditions and owners
- Exception requests, approvals, expiry dates, and closure evidence
- Reassessments triggered by incidents or scope changes

8. Trigger events (mandatory re-assessment)

Re-assessment is required upon:

- new data types or increased data volume
- new integration pattern (API write access, network connectivity, agents)

- privileged access requested or expanded
- material supplier incident/breach
- significant sub-processor changes
- renewal of a Critical supplier contract